

Rapport final - Etape 9 : Hardening securite + validation E2E

Projet : amir-digital-store-v2 - Date : 5 septembre 2026

Mission : audit de securite applicatif approfondi du parcours e-commerce (catalogue -> panier -> checkout -> commande -> Stripe -> webhook -> paid -> downloads -> admin). Aucune nouvelle fonctionnalite metier ajoutée.

1. Audit - vulnerabilites trouvees

[V1][HIGH] server/routers.ts, server/db.ts

orders.createCheckoutSession({orderId}) sans capacite : orderId sequentiel enumerable. N'importe qui pouvait attacher une session Stripe a la commande d'un autre (bloquant l'acheteur legitime) et pousser son email vers Stripe. Correction : nouveau orders.accessToken (hex 256-bit, randomBytes), minte a la creation, compare en temps constant (isOrderTokenValid), exige pour ouvrir la session Stripe. Erreur generique unique (plus d'oracle d'existence).

[V2][MEDIUM] server/db.ts

markOrderPaid/attachPaymentReference ne gardaient que paymentStatus : un webhook tardif pouvait re-basculer une commande cancelled/refunded a paid. Correction : garde ajoutée status = pending (idempotence conservee).

[V3][HIGH] server/downloads.ts

(a) Chaque visite de la page succes inserait de nouveaux grants (URLs actives illimitées). (b) Compteur downloadCount < max verifie puis incremente en deux requetes (depassement possible en concurrence). Correction : revocation des grants precedents par (order, asset) avant mint ; increment atomique conditionnel (UPDATE ... WHERE tokenHash AND expiresAt > now AND count < max, affectedRows verifie).

[V4][MEDIUM] server/_core/index.ts

Body JSON 50mb injustifie (DoS). Correction : 1mb ; webhook raw-body preserve (route declaree avant le parser). + headers X-Content-Type-Options, X-Frame-Options: DENY, Referrer-Policy, X-Powered-By supprime.

[V5][LOW] server/routers.ts, server/admin.ts

Erreurs admin renvoyant error.message brut (internes DB fuitables). Correction : PublicSafeError pour erreurs metier sures, safeAdminMessage() avec fallback generique sinon.

[V6][LOW] server/admin.ts

Recherche admin brute dans LIKE (wildcards %/_). Correction : escapeLikePattern().

[V7][LOW] server/storage.ts

resolve() sans resolution de symlinks. Correction : verification realpath + re-contrôle du prefixe dans exists()/download().

[V8][INFO] server/payments.ts

async_payment_succeeded ne verifiait pas payment_status. Correction : paid exige pour les deux types d'evenements.

[V9][INFO] server/routers.ts

createCheckoutSession fuitait 'Order not found' vs 'session already exists' (oracle). Correction : message unique generique. Aucun secret cote client (VITE_* : IDs/URLs uniquement).

Audites et juges sains

- orders.create : prix/totaux ignores, rechargement DB, unpublished refuses, quantites 1-99, <=100 items, anti-mix devises.
- JWT session (HS256, alg fixe), OAuth (nonce state + cookie __Host-, redirect fixe /), role depuis DB, cron force user.
- success_url jamais preuve (re-verification API Stripe), token download (32 octets, hash SHA-256, expiry).
- FK restrict/cascade, .env ignore par Git.

2. Corrections - fichiers modifies

drizzle/schema.ts (+ migration drizzle/0005_lucky_firebird.sql : orders.accessToken), server/db.ts, server/payments.ts, server/downloads.ts, server/storage.ts, server/admin.ts, server/routers.ts, server/_core/index.ts, client/src/pages/Checkout.tsx (transmet le token, en memoire uniquement). Aucune feature metier ; architectures Stripe/auth/Drizzle/tRPC inchangees.

3. Tests securite : 24 avant -> 51 apres, 51/51 OK

Nouveaux : server/security.test.ts (17 tests : prix/total forges ignores, quantites extremes, isOrderTokenValid, validation token checkout, tokens vides/surdimensionnes, traversal ../absolu/backslash/symlink, hygiene erreurs admin, scan anti-setPaid) + server/webhook.test.ts (10 tests : signatures, redelivrance, unpaid, metadata, paid verifie).

4. Validation

- pnpm install --frozen-lockfile : OK
- pnpm run check : OK
- pnpm test : OK (51/51)
- pnpm run build : OK
- drizzle-kit check : OK
- Smoke serveur build : admin.dashboard anonyme -> 403 OK ; checkout sans token -> 400 generique OK ; headers presents OK.

5. Tests reels

Teste reellement : RBAC/IDOR (18 endpoints x anonyme/user, 403), validation Zod, signatures webhook (vraie verif HMAC), routage evenements, traversal stockage, erreurs generiques, headers HTTP, build.

Non teste : MySQL reel, Stripe reel, webhook reel, telechargement reel, migration 0005 appliquee.

Impossible faute d'environnement : DATABASE_URL vide, pas de STRIPE_*, pas de PRIVATE_STORAGE_ROOT reel.

6. Risques restants

- 1. Commandes legacy (accessToken NULL) payables sans token - transitionnel.
- 2. Ecrasement du nom client sur commande repetee (inherent au guest checkout).
- 3. Pas de rate limiting (spam de commandes = remplissage DB).
- 4. VITE_FRONTEND_FORGE_API_KEY exposee par design du template.
- 5. Projet NON declare production-ready : validation MySQL + Stripe test requise avant production.